DEVSECOPS-SBOM-SECURITY-QUALITY

DevSecOps·SBOM과 보안 품질 자동화

연관 기출 · 135-2-2, 136-4-6, 131-1-13, 134-3-3

한눈에 이해

보안을 마지막 검사 한 번에 맡기지 않고 코드·의존성·빌드·배포·운영에 검증과 책임을 연결합니다.

정의와 핵심 원리

DevSecOps는 개발·보안·운영이 보안 목표와 책임을 공유하고 CI/CD 수명 주기에 보안 활동을 통합하는 접근입니다. SBOM은 소프트웨어 구성 요소와 관계를 표현하는 목록이며 보안 품질은 기밀성·무결성·가용성 등 보호 요구를 만족하는 제품·운영 특성으로 평가합니다.

• NIST SSDF 1.1은 조직 준비(PO), 소프트웨어 보호(PS), 안전한 소프트웨어 생산(PW), 취약점 대응(RV)의 실무군을 제시합니다. 보안 요구·위협 모델·안전 설계·구현 검토·시험·취약점 접수·수정·원인 분석을 기존 개발 방법에 통합합니다.

• 커밋에서 비밀 정보를 찾고 SAST로 소스 코드를 검사합니다. SCA로 의존성과 라이선스를 확인하고 컨테이너·IaC 설정을 검사합니다. DAST와 API 보안 시험을 거쳐 서명·빌드 출처와 배포 정책을 확인합니다. 운영 중에는 위협을 탐지하고 패치합니다. 탐지 규칙·심각도·실제 도달성·예외 승인·기한·재검증을 관리하지 않으면 경보가 쌓이거나 배포를 불필요하게 막습니다.

• SBOM의 이름·버전·공급자·식별자·의존 관계 등은 실제 배포물과 연결해야 합니다. 취약점 목록과 동일한 문서가 아니며 새 취약점 발표 시 해당 구성의 영향을 찾는 데 도움이 됩니다. 목록 정확성·갱신·서명·취약점 DB·VEX 같은 적용성 정보와 분석을 결합합니다.

구조·비교·판단

구분	핵심 원리	적용·한계
SAST/DAST	소스/실행 행위 분석	오탐·누락·범위
SCA/SBOM	의존성 위험 분석 / 구성 요소 목록	버전·도달성·갱신
배포·운영 통제	서명·정책·관측	권한·예외·사고 복구

적용 예제

새 취약점의 영향 추적

강사 생성 학습 예제입니다. 공식 기준답안이 아닙니다.

조건: 여러 서비스에 배포한 공통 라이브러리의 취약점이 공개됩니다.

1. SBOM에서 실제로 포함된 버전과 배포 서비스를 찾습니다.
2. 공격 가능성과 업무 중요도를 평가합니다.
3. 수정 버전 시험·서명·배포를 실행하고 예외는 기한과 보완 통제를 기록합니다.
4. 수정 확인과 유사 결함의 근본 원인 개선을 수행합니다.

결과·해석: 보안 품질을 도구 실행 횟수보다 위험 감소·조치 완료·재발 방지로 검증합니다.

전제·주의: 도구가 모든 보안 결함·라이선스 위반을 찾는 것은 아닙니다. SBOM 형식의 필드 전 항은 각 규격 판본을 확인합니다.

답안 골격과 혼동 방지

보안 품질과 책임 → SSDF의 4가지 실무군 → 파이프라인 검사 도식 → SBOM 활용 예제 → 지표·예외

- 스캐너 통과를 절대 안전 인증으로 쓰지 않습니다.
- SBOM과 취약점 스캔 결과를 동일시하지 않습니다.

내용을 가리고 회상

1. 보안 자동화에 예외 기한이 필요한 이유는 무엇입니까?
2. SBOM이 0-day 발표 후 어떻게 도움이 됩니까?
3. SSDF의 취약점 대응은 개발 과정의 개선에 어떻게 쓰입니까?

적용 기준과 근거

명시한 출처 판본의 원리를 설명하며 제품별 구현 차이는 별도 확인합니다.

내용 검토 상태: 출처 확인. 출처 확인은 공식 정답이나 학습 성취를 뜻하지 않습니다.

출처별 상세 열람 범위는 위키의 출처 기록에서 확인합니다.

- NIST SP800-218 SSDF1.1 - Murugiah Souppaya;Karen Scarfone;Donna Dodson / NIST; 2022-02; 확인 2026-11-05.
- ScanCode Toolkit Documentation - AboutCode / ScanCode project; 상시문서; 확인 2026-11-05.